Cloud Networking

Appunti - AWS Cloud Security e IAM

Basati sul PDF: 06 - CN - AWS Cloud Security and IAM

> Obiettivo degli appunti: spiegare passo passo il modello di responsabilita condivisa AWS e il funzionamento di IAM, con attenzione ai punti tipici da esame: chi e responsabile di cosa, differenza tra autenticazione e autorizzazione, utenti/gruppi/policy/ruoli, MFA e regole di valutazione dei permessi.

Indice degli argomenti

- 1. AWS Shared Responsibility Model
- 2. Responsabilita AWS: security of the cloud
- 3. Responsabilita del customer: security in the cloud
- 4. AWS Identity and Access Management (IAM)
- 5. Autenticazione IAM: accesso programmatico, console e MFA
- 6. Autorizzazione IAM, policy e principio del least privilege
- 7. Logica di valutazione dei permessi IAM
- 8. Lab 1: struttura finale utenti, gruppi e policy
- 9. Glossario e domande d'esame con risposta sotto ogni domanda

1. AWS Shared Responsibility Model

Il modello di responsabilita condivisa AWS stabilisce che sicurezza e compliance non sono compito esclusivo ne di AWS ne del cliente: sono divise tra provider e customer. La divisione principale e tra security of the cloud e security in the cloud.

> Formula da ricordare: AWS protegge l'infrastruttura del cloud; il cliente protegge cio che configura, installa, carica e gestisce dentro il cloud.

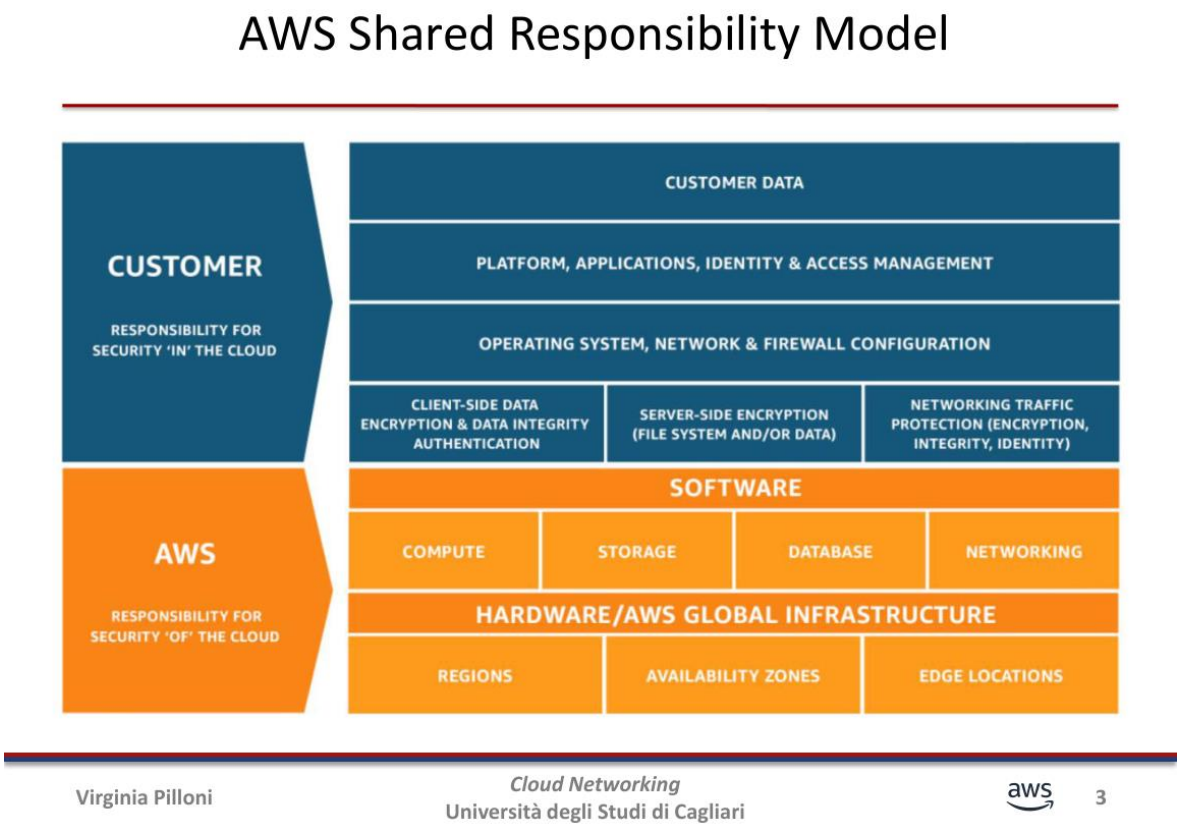


Figura 1 - AWS Shared Responsibility Model: AWS gestisce l'infrastruttura sottostante, il customer gestisce dati, applicazioni, identita, configurazioni e protezioni applicative.

Area	Responsabile principale	Significato pratico
Security of the cloud	AWS	AWS protegge hardware, software di base, networking, data center, regioni, Availability Zones ed edge locations.
Security in the cloud	Customer	Il cliente protegge dati, account, identita, applicazioni, sistemi operativi delle istanze, firewall, security group e cifratura.
Compliance	Condivisa	AWS fornisce infrastruttura e controlli; il cliente deve configurare correttamente servizi, permessi e gestione dei dati.

1.1 Perche il modello e importante

- Evita l'errore di pensare che, usando il cloud, tutta la sicurezza sia delegata ad AWS.

- Chiarisce quali livelli tecnici sono gestiti dal provider e quali restano sotto il controllo del cliente.
- Permette di capire perche, ad esempio, una configurazione errata di un bucket S3 o di un security group e responsabilita del cliente, non di AWS.
- Aiuta a ragionare nei laboratori AWS: ogni volta che si crea una risorsa, bisogna chiedersi quali configurazioni di sicurezza dipendono da noi.

1.2 Security of the cloud vs security in the cloud

Concetto	Descrizione	Esempi
Security of the cloud	Riguarda la protezione dell'ambiente cloud sottostante su cui girano tutti i servizi AWS.	Sicurezza fisica dei data center, alimentazione, rete globale, storage fisico, isolamento della virtualizzazione.
Security in the cloud	Riguarda la protezione delle risorse create e configurate dal cliente dentro AWS.	Cifratura dati, gestione IAM, patch dell'OS EC2, security group, firewall host-based, configurazione applicazioni.

2. Responsabilita di AWS: Security of the Cloud

AWS e responsabile della protezione dell'infrastruttura che esegue i servizi AWS. Questo include i livelli dal software di virtualizzazione verso il basso fino alla sicurezza fisica delle strutture.

2.1 Componenti sotto responsabilita AWS

Componente	Cosa fa AWS	Perche conta
Sicurezza fisica dei data center	Accesso controllato e basato sulla necessita effettiva.	Riduce il rischio che persone non autorizzate accedano fisicamente a server e dispositivi.
Infrastruttura hardware e software	Gestione di storage, host OS, logging, auditing e dismissione sicura dello storage.	Garantisce che le risorse fisiche siano gestite in modo sicuro lungo il ciclo di vita.
Infrastruttura di rete	Protezione e monitoraggio della rete, inclusa intrusion detection.	Riduce il rischio di compromissioni della rete AWS.
Virtualizzazione	Isolamento delle istanze dei clienti.	Permette a piu clienti di condividere l'infrastruttura senza interferire tra loro.
Global Infrastructure	Gestione di Regions, Availability Zones ed Edge Locations.	Fornisce resilienza, disponibilita e performance globali.

> Da esame: se la domanda riguarda data center, hardware fisico, rete globale AWS, Availability Zone, edge location o isolamento della virtualizzazione, la responsabilita principale e di AWS.

3. Responsabilita del customer: Security in the Cloud

Il customer e responsabile delle scelte di configurazione e gestione delle risorse che usa. In particolare, deve proteggere dati, applicazioni, identita, accessi, sistemi operativi e configurazioni di rete.

3.1 Responsabilita principali del customer

Area	Responsabilita del cliente	Esempio concreto
Customer data	Proteggere i dati caricati, trattati e archiviati nei servizi AWS.	Decidere quali dati cifrare, chi puo leggerli, dove conservarli e come gestirli.
Applicazioni e IAM	Configurare applicazioni, utenti, gruppi, ruoli, password e permessi.	Creare utenti IAM con privilegi minimi invece di usare account condivisi.
Sistema operativo	Gestire patch, manutenzione e hardening delle istanze EC2.	Aggiornare il sistema operativo di una VM EC2 e correggere vulnerabilita.
Network e firewall	Configurare security group, firewall e regole di rete.	Consentire solo porte necessarie, ad esempio HTTP/HTTPS o SSH da IP affidabili.
Cifratura	Gestire cifratura client-side, server-side e protezione del traffico.	Usare HTTPS/TLS per dati in transito e cifratura a riposo per file o database.
Account management	Gestire credenziali, login e permessi degli utenti.	Abilitare MFA e ruotare le chiavi di accesso.

3.2 Esempio pratico su EC2

Con Amazon EC2 il cliente ottiene una macchina virtuale. AWS gestisce data center, hardware, hypervisor e infrastruttura sottostante. Il cliente invece deve gestire il sistema operativo installato, gli aggiornamenti di sicurezza, le applicazioni, gli accessi e le regole di rete associate all'istanza.

> Errore tipico: pensare che AWS aggiorni automaticamente il sistema operativo di una istanza EC2. Nel modello EC2, la patching responsibility dell'OS e del software installato ricade sul customer.

4. AWS Identity and Access Management (IAM)

AWS Identity and Access Management, abbreviato IAM, e il servizio AWS usato per controllare in modo centralizzato l'accesso ai servizi e alle risorse cloud. IAM permette di gestire autenticazione e autorizzazione.

Domanda logica	Risposta IAM
Chi puo accedere?	Utenti, gruppi, ruoli o servizi autorizzati.
A quali risorse puo accedere?	Risorse AWS specifiche, ad esempio bucket S3, istanze EC2, tabelle DynamoDB.
Cosa puo fare sulla risorsa?	Azioni/API consentite, ad esempio leggere, scrivere, creare, eliminare, avviare o fermare.
Come puo accedere?	Console, AWS CLI, SDK, API, ruoli temporanei e credenziali configurate.

4.1 Autenticazione e autorizzazione

Concetto	Significato	Esempio AWS
Autenticazione	Verifica dell'identita: il sistema controlla chi sei.	Login con account ID/alias, username, password e magari MFA.
Autorizzazione	Verifica dei permessi: il sistema	Una policy consente a un utente

	controlla cosa puoi fare.	di leggere un bucket S3 ma non eliminarlo.

> IAM non serve solo a creare utenti: serve soprattutto a definire permessi precisi e granulari sulle risorse AWS.

4.2 Componenti essenziali di IAM

Componente IAM	Definizione	Quando si usa
IAM user	Persona o applicazione che puo autenticarsi con un account AWS.	Quando serve un'identita stabile con credenziali proprie.
IAM group	Collezione di utenti IAM con le stesse autorizzazioni.	Quando piu utenti devono avere lo stesso set di permessi.
IAM policy	Documento che definisce quali risorse possono essere accedute e con quale livello di accesso.	Quando bisogna concedere o negare azioni su risorse AWS.
IAM role	Meccanismo per concedere un set di permessi per effettuare richieste ai servizi AWS.	Quando un servizio, un'istanza o un utente deve assumere permessi temporanei.

5. Autenticazione IAM: accesso programmatico, console e MFA

Quando si definisce un utente IAM, si stabilisce anche il tipo di accesso che puo usare. Le slide distinguono soprattutto accesso programmatico e accesso tramite AWS Management Console.

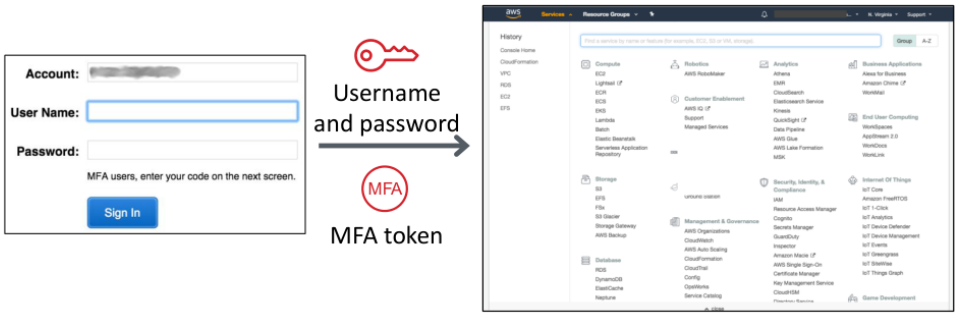
Tipo di accesso	Credenziali usate	Strumenti tipici
Programmatic access	Access key ID + Secret access key.	AWS CLI e AWS SDK.
AWS Management Console access	Account ID o alias + IAM username + IAM password.	Console web AWS.
Console con MFA	Username/password + codice MFA temporaneo.	Console AWS con maggiore sicurezza.

5.1 MFA - Multi-Factor Authentication

La MFA aumenta la sicurezza perche non basta conoscere username e password: serve anche un codice temporaneo generato da un dispositivo o applicazione MFA.

IAM MFA

- MFA provides increased security
- In addition to **username** and **password**, MFA requires a unique authentication code to access AWS services
  - Options for generating the MFA authentication token include **virtual MFA-compliant applications** (such as Google Authenticator or Authy 2-Factor Authentication), and **hardware MFA devices**



AWS Management Console

Figura 2 - IAM MFA: oltre a username e password, viene richiesto un token di autenticazione temporaneo.

Elemento	Descrizione
Fattore 1	Qualcosa che conosci: username e password.
Fattore 2	Qualcosa che possiedi: token MFA generato da app o dispositivo hardware.
Esempi di generatori MFA	Google Authenticator, Authy 2-Factor Authentication, hardware MFA devices.

> Da ricordare: la MFA riduce il rischio che un account venga compromesso solo tramite password rubata o indovinata.

6. Autorizzazione IAM e principio del least privilege

Dopo l'autenticazione, AWS deve decidere se l'utente puo effettivamente eseguire una certa azione. Questa fase e l'autorizzazione e si basa sui permessi IAM.

6.1 Regole fondamentali dei permessi IAM

- Tutti i permessi sono implicitamente negati di default.
- Una permission esplicitamente consentita permette l'azione solo se non esiste un deny esplicito.
- Un deny esplicito prevale sempre su un allow.
- La best practice e applicare il principle of least privilege: concedere solo i permessi minimi necessari.
- Le configurazioni IAM hanno scope globale: si applicano a tutte le AWS Regions.

6.2 Least privilege

Il principio del least privilege richiede di partire da un set minimo di permessi e aggiungere privilegi solo quando sono realmente necessari. Questo riduce il danno potenziale in caso di credenziali compromesse o errore umano.

Approccio sbagliato	Approccio corretto
Dare permessi amministrativi a tutti gli utenti per evitare problemi.	Dare a ciascun utente solo le azioni necessarie al suo ruolo.
Usare account condivisi.	Creare utenti o ruoli separati, tracciabili e con MFA dove necessario.
Lasciare aperte azioni non usate.	Rimuovere permessi inutili e revisionare periodicamente le policy.

7. IAM Policies

Una IAM policy e un documento che definisce i permessi. In pratica dice quali azioni sono consentite o negate e su quali risorse AWS.

Tipo di policy	Dove si attacca	Caratteristiche
Identity-based policy	A un'entita IAM: user, group o role.	Definisce cosa puo o non puo fare quell'identita.
Resource-based policy	A una risorsa AWS, ad esempio un bucket S3.	Definisce chi puo accedere a quella risorsa; supportata solo da alcuni servizi.

7.1 Struttura logica di una policy

Campo	Significato
Effect	Stabilisce se la regola e Allow oppure Deny.
Action	Indica le azioni/API AWS coinvolte, ad esempio s3:GetObject o ec2:StartInstances.
Resource	Indica la risorsa a cui si applica la policy, spesso tramite ARN.
NotResource	Indica le risorse escluse da una certa regola; nel caso mostrato nelle slide serve a negare tutto cio che non e nelle risorse specificate.

7.2 Esempio semplificato di policy

Le slide mostrano una policy che consente l'accesso a una tabella DynamoDB e a specifici bucket S3, negando invece l'uso di altre azioni o risorse non previste. Il punto chiave non e memorizzare tutto il JSON, ma capire la logica: allow mirato + deny esplicito di cio che non deve essere usato.

```
{
  "Effect": "Allow",
  "Action": ["dynamodb:*", "s3:*"],
  "Resource": ["specific DynamoDB table", "specific S3 bucket"]
},
{
  "Effect": "Deny",
  "Action": ["dynamodb:*", "s3:*"],
  "NotResource": ["specific DynamoDB table", "specific S3 bucket"]
```

```
}
```

> Regola chiave: un explicit deny ha precedenza su un allow. Quindi, anche se una policy consente un'azione, un'altra policy che la nega esplicitamente blocca comunque l'accesso.

7.3 Come IAM determina i permessi

Passaggio	Domanda	Risultato
1	La permission e esplicitamente negata?	Se si: Deny immediato.
2	Se non e negata, la permission e esplicitamente consentita?	Se si: Allow.
3	Se non esiste nessun allow esplicito?	Deny implicito.

Questa logica e molto importante per l'esame: AWS parte dal deny implicito, concede solo cio che e esplicitamente permesso e blocca sempre cio che e esplicitamente negato.

8. Lab 1: Introduction to IAM

Il laboratorio serve a sperimentare direttamente come utenti, gruppi e policy influenzano l'accesso alle risorse AWS. L'obiettivo non e solo creare oggetti IAM, ma osservare gli effetti concreti dei permessi.

8.1 Attivita previste nel lab

- Esplorare utenti e gruppi IAM gia creati.
- Ispezionare le IAM policy applicate ai gruppi.
- Aggiungere utenti a gruppi con capacita specifiche.
- Trovare e usare l'IAM sign-in URL.
- Verificare come le policy IAM cambiano l'accesso alle risorse AWS.

8.2 Prodotto finale del lab

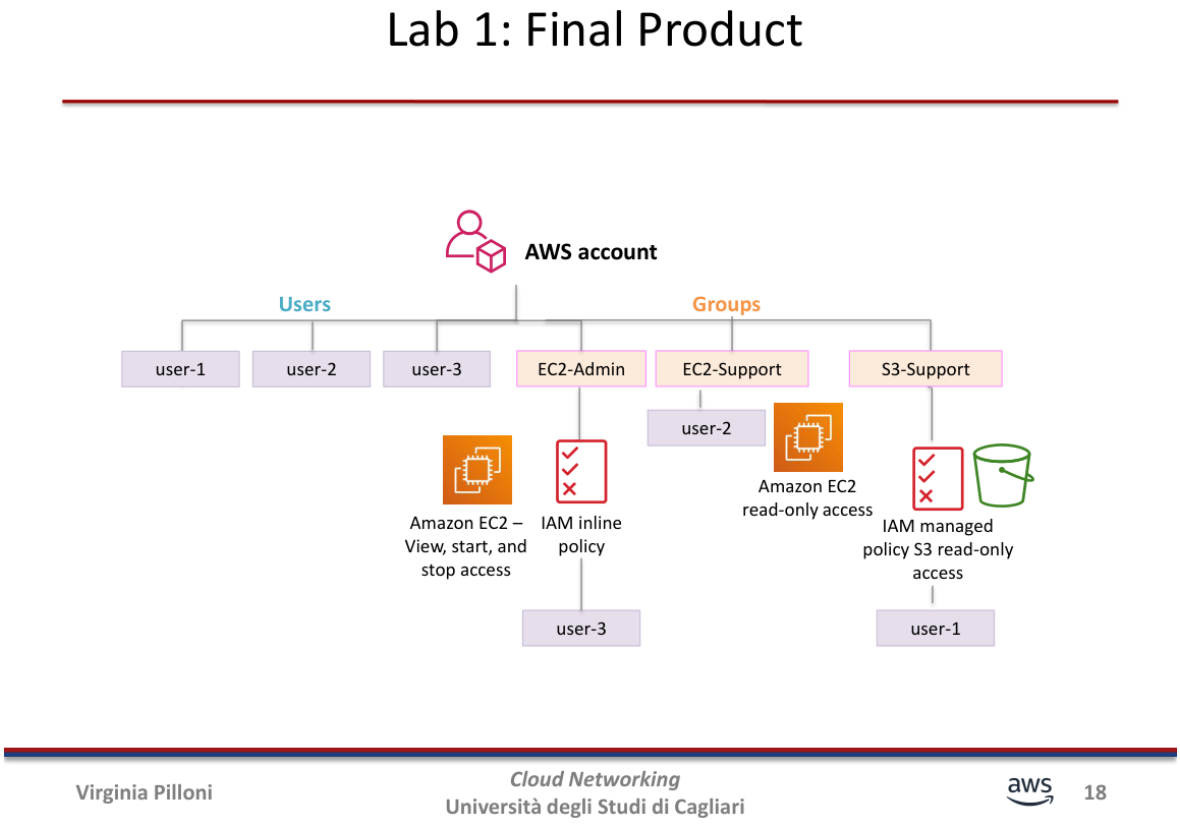


Figura 3 - Lab 1 final product: utenti associati a gruppi IAM con policy diverse per EC2 e S3.

Utente	Gruppo	Permessi associati
user-1	S3-Support	Accesso read-only ad Amazon S3 tramite IAM managed policy.
user-2	EC2-Support	Accesso read-only ad Amazon EC2.
user-3	EC2-Admin	Accesso EC2 per visualizzare, avviare e fermare istanze tramite IAM inline policy.

> Interpretazione del lab: i gruppi sono usati per assegnare permessi in modo ordinato. Gli utenti non dovrebbero ricevere permessi casuali uno per uno: conviene collegarli a gruppi o ruoli coerenti con la loro funzione.

9. Schema rapido da ripasso

Tema	Idea chiave da ricordare
Shared Responsibility	AWS protegge il cloud; il customer protegge cio che mette e configura nel cloud.
AWS responsibility	Data center, hardware, rete globale, virtualizzazione e infrastruttura fisica/logica sottostante.
Customer responsibility	Dati, cifratura, IAM, OS EC2, applicazioni, security group, firewall, account e permessi.
IAM	Servizio globale per controllare autenticazione e autorizzazione in AWS.
MFA	Aggiunge un secondo fattore oltre a username e password.

Policy	Documento che definisce allow/deny su azioni e risorse.
Least privilege	Dare solo i privilegi minimi necessari.
Explicit deny	Ha sempre precedenza su allow.

10. Glossario essenziale

Termine	Significato
AWS Shared Responsibility Model	Modello che divide le responsabilita di sicurezza tra AWS e cliente.
Security of the Cloud	Sicurezza dell'infrastruttura cloud gestita da AWS.
Security in the Cloud	Sicurezza delle risorse e configurazioni gestite dal cliente dentro AWS.
IAM	Servizio AWS per gestire identita, accessi e permessi.
IAM user	Identita IAM associata a una persona o applicazione.
IAM group	Collezione di utenti con autorizzazioni comuni.
IAM policy	Documento che definisce permessi sulle risorse AWS.
IAM role	Identita assumibile con un set di permessi, utile per servizi e accessi temporanei.
MFA	Multi-Factor Authentication: autenticazione con piu fattori.
Programmatic access	Accesso tramite chiavi usate da AWS CLI o SDK.
Console access	Accesso tramite interfaccia web AWS Management Console.
Implicit deny	Negazione predefinita: cio che non e esplicitamente consentito e negato.
Explicit deny	Negazione dichiarata in policy, sempre prioritaria rispetto agli allow.
Least privilege	Principio secondo cui si concedono solo i permessi minimi necessari.

11. Domande d'esame con risposta

Le domande sono organizzate nel formato richiesto: ogni domanda ha subito sotto la risposta, cosi puoi usarle direttamente per il ripasso.

Domanda: Che cosa afferma l'AWS Shared Responsibility Model?

Risposta: Afferma che sicurezza e compliance sono responsabilita condivise: AWS e responsabile della security of the cloud, mentre il cliente e responsabile della security in the cloud.

Domanda: Che cosa significa security of the cloud?

Risposta: Significa sicurezza dell'infrastruttura AWS: data center, hardware, software di virtualizzazione, networking, storage fisico, Regions, Availability Zones ed Edge Locations.

Domanda: Che cosa significa security in the cloud?

Risposta: Significa sicurezza delle risorse configurate dal cliente: dati, applicazioni, IAM, sistema operativo delle istanze EC2, security group, firewall, cifratura e gestione degli account.

Domanda: Chi e responsabile della sicurezza fisica dei data center AWS?

Risposta: AWS. Il provider controlla accessi fisici, strutture, hardware, alimentazione, rete e sicurezza dei data center.

Domanda: Chi e responsabile del patching del sistema operativo di una istanza EC2?

Risposta: Il customer. In EC2 il cliente gestisce sistema operativo, aggiornamenti, applicazioni e configurazioni di sicurezza dell'istanza.

Domanda: A cosa serve AWS IAM?
Risposta: IAM serve a controllare l'accesso ai servizi e alle risorse AWS, gestendo autenticazione, autorizzazione e permessi granulari.

Domanda: Qual e la differenza tra autenticazione e autorizzazione?
Risposta: L'autenticazione verifica chi sei; l'autorizzazione verifica cosa puoi fare dopo che sei stato riconosciuto.

Domanda: Quali sono i componenti essenziali di IAM?
Risposta: IAM user, IAM group, IAM policy e IAM role.

Domanda: Che cos'e un IAM user?
Risposta: E una persona o applicazione che puo autenticarsi con un account AWS tramite credenziali specifiche.

Domanda: Che cos'e un IAM group?
Risposta: E una collezione di IAM users a cui vengono assegnate autorizzazioni comuni.

Domanda: Che cos'e una IAM policy?
Risposta: E un documento che definisce quali azioni sono consentite o negate e su quali risorse AWS.

Domanda: Che cos'e un IAM role?
Risposta: E un meccanismo per concedere un set di permessi, spesso usato per richieste tra servizi AWS o accessi temporanei.

Domanda: Quali credenziali servono per l'accesso programmatico?
Risposta: Access key ID e secret access key, usate da AWS CLI e AWS SDK.

Domanda: Quali credenziali servono per accedere alla AWS Management Console?
Risposta: Account ID o alias, IAM username e IAM password; se MFA e abilitata serve anche il codice MFA.

Domanda: Perche MFA migliora la sicurezza?
Risposta: Perche richiede un secondo fattore oltre alla password, rendendo piu difficile l'accesso non autorizzato in caso di password compromessa.

Domanda: Cosa significa implicit deny?
Risposta: Significa che, per impostazione predefinita, un'azione e negata se non esiste una policy che la consente esplicitamente.

Domanda: Cosa succede se una policy consente un'azione ma un'altra la nega esplicitamente?
Risposta: Prevale l'explicit deny: l'azione viene negata comunque.

Domanda: Che cosa impone il principio del least privilege?
Risposta: Impone di concedere solo i permessi minimi necessari per svolgere un compito, aggiungendo privilegi solo quando servono davvero.

Domanda: Le configurazioni IAM sono regionali o globali?
Risposta: Sono globali: le impostazioni IAM si applicano attraverso tutte le AWS Regions.

Domanda: Qual e il senso del Lab 1 su IAM?
Risposta: Mostrare in pratica come utenti, gruppi e policy determinano l'accesso alle risorse AWS e come cambiano i permessi assegnando utenti a gruppi diversi.

12. Checklist finale per l'esame

- So distinguere security of the cloud da security in the cloud.
- So dire almeno tre responsabilita di AWS e tre responsabilita del customer.
- So spiegare perche EC2 richiede gestione del sistema operativo da parte del cliente.
- So definire IAM user, group, policy e role.
- So distinguere autenticazione e autorizzazione.
- So spiegare MFA e perche e importante.
- So applicare la regola: explicit deny prevale su allow.
- So spiegare implicit deny e least privilege.
- So interpretare il prodotto finale del laboratorio IAM.